

Malware & SQL Injection

5f4**dcc**3**b**5**aa**7**65**d61d8327deb882cf**99**

Hiraku Morita

4 Mar. 2026

Malware—Agenda

- Understand viruses and how they propagate
- Have a working knowledge of several specific viruses
- Understand virus scanners
- Understand what a Trojan horse is

Viruses

A computer virus

- Often attaches to a file
- Self-replicates
- Spreads rapidly

Difference to a worm

- Virus—Requires human action
- Worm—Can self-replicate but does not require human action

Viruses—Propagation

- e-Mail
- Network
- Web Sites

e-Mail Propagation

- More common for one major reason
- Everyone can hook up a mail server
original protocol had no checks
- Some viruses bring their own e-Mail engine
- Microsoft Outlook is easy to work with;
A few lines of code can cause Outlook
to send e-mails covertly
- Attachments

Network & Web Sites

- Network propagation
Exploits trust into network storage
Less frequent, but just as effective
- Similar: USB devices
- Web site delivery
Relies on end-user negligence
- Downloading malicious software

Types—Macro Viruses

- **Macro**—uses macros in office documents

Types—Multi-Partite Viruses

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways, e.g. opens backdoor, reverse shell, downloads files, etc.

Types—Armored

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways
- **Armored**—use techniques to make it harder to analyze, e.g. Base64, obfuscation, etc.

```
payload = 'ZGVmIHNjYW4oKT0NCiAgICBwcmludCgnXG4nKQ0KICAgIGRvc2Nhbi'  
code = base64.b64decode(payload).decode('utf-8')  
exec(code)
```

Types—Memory Resident

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways
- **Armored**—use techniques to make it harder to analyze
- **Memory Resident**—installs itself and remains in RAM

Types—Sparse Infector

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways
- **Armored**—use techniques to make it harder to analyze
- **Memory Resident**—installs itself and remains in RAM
- **Sparse Infector**—stealth via reduced attack frequency

Types—Polymorphic

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways
- **Armored**—use techniques to make it harder to analyze
- **Memory Resident**—installs itself and remains in RAM
- **Sparse Infector**—stealth via reduced attack frequency
- **Polymorphic**—changes its form to avoid detection

Types

- **Macro**—uses macros in office documents
- **Multi-Partite**—attacks the computer in multiple ways
- **Armored**—use techniques to make it harder to analyze
- **Memory Resident**—installs itself and remains in RAM
- **Sparse Infector**—stealth via reduced attack frequency
- **Polymorphic**—changes its form to avoid detection

It is becoming more common for viruses to use multiple vectors

Virus Strains

- It is often not so difficult to create new strains
- Why?
 - Small effects achievable with small changes
e.g., IPs, downloads, target selection
 - Scripts are readable and alterable
 - Reverse engineering, e.g., with [NSA's GHIDRA](#) 
i.e., disassemblers allow large changes; recompile possible
- Re-use and combination of efficient solutions
- Availability of virus tool boxes

The First Internet Worm?

Robert Tappan Morris

From Wikipedia, the free encyclopedia

For other people named Robert Morris, see [Robert Morris \(disambiguation\)](#).

Robert Tappan Morris (born November 8, 1965) is an American computer scientist and entrepreneur. He is best known^[a] for creating the *Morris Worm* in 1988, considered the first computer worm on the Internet.^[4]

Morris was prosecuted for releasing the worm, and became the first person convicted under the then-new *Computer Fraud and Abuse Act*.^{[2][3]} He went on to co-found the online store *Viaweb*, one of the first web-based applications,^[5] and later the funding firm *Y Combinator*—both with *Paul Graham*.

He later joined the faculty in the department of Electrical Engineering and Computer Science at the *Massachusetts Institute of Technology*, where he received *tenure* in 2006.^[7]

Contents

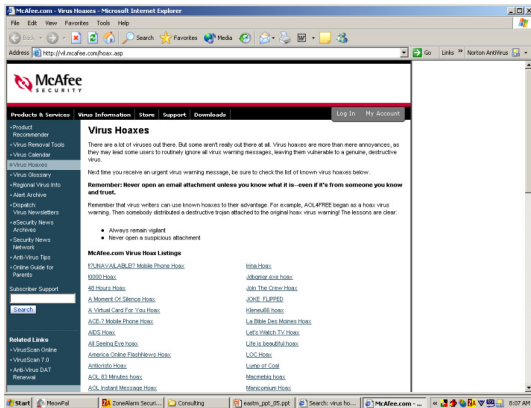
- 1 Early life
- 2 Morris worm
 - 2.1 Criminal prosecution
- 3 Later life and work
 - 3.1 Timeline
- 4 See also
- 5 References
- 6 Further reading and external links



- Did not mean to cause harm
- But Convicted
 - 3yrs probation, 400hrs of community service
 - 10,000 USD
- Exploited bugs in programs it exploited, sendmail, rsh (shell)
- But bugs in the code allowed a computer to infected multiple times

Robert Tappan Morris, Jr. stated... “to demonstrate the inadequacies of current security measures on computer networks by exploiting the security defects [he] had discovered.”

Virus Hoaxes



Other hoax:

FakeAV (2012) and

MacDefender (2011)

Virus hoaxes from the McAfee site

How to Avoid Viruses

- Use virus scanners & other filters
- Locally, in your mail server, on network storage
- Never open questionable attachments
- Use cryptographic signatures to verify the *origin* and the *content*
- Does it make sense to use heterogeneous software environments?

Ransomware

- AIDS trojan (1989)
- Cryptolocker (2013–2014)
- Cryptowall ($\approx$ 2015)
- Can be staged, 1. *Macro* in Office document, *LNK files* with embedded powershell script..., 2. download actual malware.
- Example tools for ransomware attacks can be found online
- Data restored for 94 percent of ransom payers, twice as many had backups [Sophos, 2020](#) 

Trojan Horses

A program that looks benign, but is not...

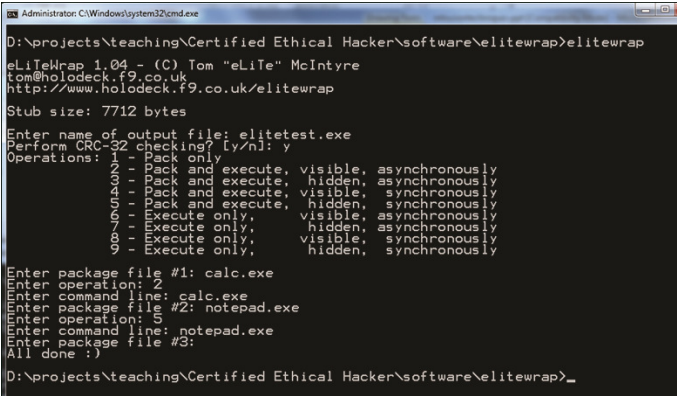
- A cute screen saver or apparently useful login box can
 - Download harmful software.
 - Install a key logger .
 - Open a back door for hackers.

Trojan Horses

- Competent programmers can craft a Trojan horse:
 - To appeal to a certain person or
 - To appeal to a certain demographic
- Company policy should prohibit unauthorized downloads.

Trojan Horses: Wrappers

- EliteWrap.



```
Administrator: C:\Windows\system32\cmd.exe
D:\projects\teaching\Certified Ethical Hacker\software\elitewrap>elitewrap
eLiTeWrap 1.04 - (C) Tom "eLiTe" McIntyre
tom@holodeck.f9.co.uk
http://www.holodeck.f9.co.uk/elitewrap
Stub size: 7712 bytes
Enter name of output file: elitetest.exe
Perform CRC-32 checking? [y/n]: y
Operations: 1 - Pack only
           2 - Pack and execute, visible, asynchronously
           3 - Pack and execute, hidden, asynchronously
           4 - Pack and execute, visible, synchronously
           5 - Pack and execute, hidden, synchronously
           6 - Execute only, visible, asynchronously
           7 - Execute only, hidden, asynchronously
           8 - Execute only, visible, synchronously
           9 - Execute only, hidden, synchronously
Enter package file #1: calc.exe
Enter operation: 2
Enter command line: calc.exe
Enter package file #2: notepad.exe
Enter operation: 5
Enter command line: notepad.exe
Enter package file #3:
All done :)
D:\projects\teaching\Certified Ethical Hacker\software\elitewrap>_
```

- Others see: <https://www.informit.com/articles/article.aspx?p=102181&seqNum=2>

Spyware

- Forms of spyware
 - Web cookies
 - Key loggers

Spyware

- Requires more technical knowledge
- Usually used for targets of choice
- Must be tailored to specific circumstances
- Must then be deployed

Spyware with Legal Uses?

- Monitoring family computer use,
- especially for minors?
- Monitoring employees?
- With or without their knowledge?
- Where is the border between legal and illegal use?
- Very much depends on where you are ...

[Legal issues of employee monitoring 

Spyware

- Who can you spy on?
 - When is it legal to use spyware?
 - In Florida, a wife used spyware to gather evidence. The wife who installed spyware on her husband's computer to secretly record evidence of an extramarital affair violated Florida law. The Florida Appeals Court said that she "illegally obtained" records of her husband's online conversations with another woman.

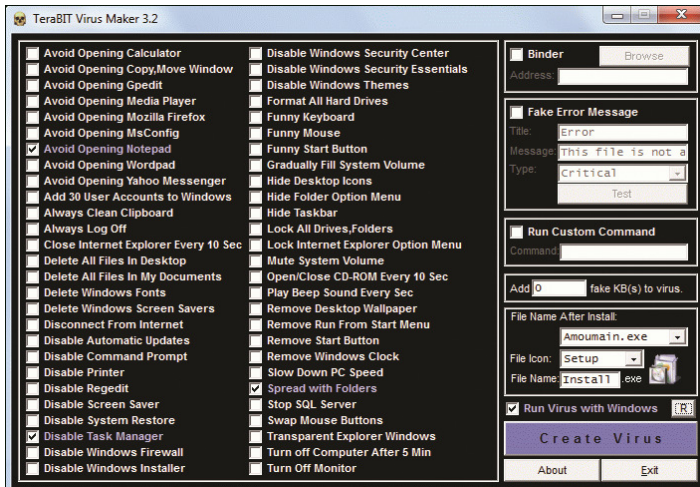
Other Malware I

- Rootkit
 - gives complete administrator access to a computer or network
 - It's a collection of hacking tools that can
 - Monitor traffic and keystrokes
 - Create a backdoor
 - Alter log files and existing tools to avoid detection
 - Attack other machines on the network

Other Malware II

- Rootkit
 - E.g., eBlaster by Veriato
 - Legal use?
 - Argument similar to that we had on spyware
 - Companies sell them as
 - User behavior Analysis tools or
 - Employee Monitoring Software

Virus Creation Toolkits



Detecting and Eliminating Viruses and Spyware

Antivirus technology for detecting viruses

- Scan for known signatures
 - Database of characteristic byte sequences
 - Known bad samples
 - ⇒ Requires regular updates
 - Can sometimes clash with program updates
- Heuristics
 - Watching the behaviour of executables
e.g., suspicious address book or registry access
 - Look for suspicious code fragments
e.g., typical hacks, using *int 80* instead of *syscall*

Malware—Summary I

- Wide variety of attacks
- Computer security essential for protecting
 - personal information
 - a company's intellectual property
- Most attacks are preventable
- Defend using sound practices (policies and training)...
- ...plus firewalls, IDS, antivirus and anti-spyware systems

Malware—Summary II

- Fancy studying source code for malware?
- A good way to learn
- But of course, do not execute the code
- Instead, contain your malware lab in a virtual machine
- Sources:
 - [theZoo](#) 
 - [MalwareBazaar](#) 
 - [Seek and ye shall find... ;-\)](#) 

SQL Injection

SQL Injection—Introduction

- One of the most common attacks
- Depends on knowledge of SQL
- Basics are easy
- Versatile and can do a lot more than many realize
- It is done by entering malicious statements or code in SQL statements via a webform or web page input field
- It can be used to destroy databases or to simply get data or information without authorization

Who is this SQL, Anyhow?

- A relational database contains one or more tables identified each by a name. Tables contain records (rows) with data.

- Example syntax for creating a table:

```
CREATE TABLE table_name (  
column1 datatype,  
column2 datatype,  
:  
columnN datatype,  
PRIMARY KEY( *one or more columns*)  
);
```

- SQL (Structured Query Language) uses commands such as SELECT, UPDATE, DELETE, INSERT, WHERE, and others.

- Example:

```
➡ SELECT * FROM tblUsers WHERE USERNAME = 'admin'
```

How to Inject into SQL

```
string sqlQuery;
```

```
sqlQuery = "SELECT * FROM tblUSERS WHERE UserName = ' " +  
txtUsername.Text + "' + " AND Password = " + txtPassword.Text + "'";
```

- **If user enters admin and pass for the username and password... after concatenation... the string will look like this**

*"SELECT * FROM tblUSERS WHERE UserName ='admin' AND Password = 'pass'";*

- So whatever you type in, gets put into the text field and added to the SQL statement

Injection

- Classic SQL Injection is Based on $1=1$ is Always True

- Rudimentary Example form has the following field:

Username: Ron OR 1=1

- The SQL code query will then be:

*SELECT * FROM tblUSERS WHERE UserId = Ron OR 1=1;*

- Then this will return all users. Why?
 - Because Ron is false (if there is no UserId named Ron),
 - But $1=1$ will always be true
- What if the Users Table has passwords?

Injection—Example

Username	Ron
Password	pass

```
userTxt = getQueryString("username");  
pass = getQueryString("userpassword");
```

```
sql = 'SELECT * FROM tblUSERS WHERE user =““ + userTxt +”” AND pass =““ + passTxt +””
```

Result is....

```
SELECT * FROM Users WHERE Name =“Ron” AND Pass =“pass”
```

Injection—Example

Username	"or ""="
Password	"or ""="

Result is....

```
SELECT * FROM Users WHERE Name ="" OR ""="" AND Pass ="" OR ""=""
```

""="" will always be true.

Injection—Example

- Some other examples that might work depending on the web application:
 - ➡ ' OR 1=1#
 - ➡ ' or '1' ='1
 - ➡ ' or 'a' ='a
 - ➡ password' or (1=1)
 - ➡ anything' OR 'x'='x
 - ➡ password:'1=1- -
- ➡ Try using double quote (") if single quote (') is not working
- ➡ But not all will work. Need to try various injections depending on the web application, MySQL version, etc.

Batch Injection

- Can also use a batch of SQL statements
- Batched SQL statements: is two or more SQL statements that are separated by semicolons.
- Example batched SQL Injection - this will delete a table (assuming there is a table called Payroll):

' OR 1=1#; DROP TABLE Payroll

SQL Injection—Summary

- Use *prepared statements*, i.e., user input is a parameter and treated literally but not as SQL commands
- Perform input validation and sanitise user inputs
- Keep database systems up to date
- Hash passwords / encrypt sensitive information
- Do not reveal internals in error messages
i.e., differentiate logging vs user visible messages
- Apply least privilege principle to all users

Available Tools

Enumeration:

- **Dirb:** checks website contents with a dictionary
- **Nikto:** checks websites for potential security issues
- **sqlmap:** look for potential SQL vulnerabilities

Exploitation: **sqlmap** is a full SQLi tool for penetration testers.